PRADITA University

IT40613 · Digital Platform & API Economy

Keamanan API:

OAuth 2.0 dan OWASP

Pertemuan 06

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Pola Insiden
3. Autentikasi dan Otorisasi
4. OAuth 2.0
5. Identitas dan Persetujuan
6. Profil Keamanan
7. OWASP API Security
8. Pembatasan dan Pencatatan
9. Aktivitas, Ringkasan, dan Latihan

PRADITA University

Kredensialnya sah.
Vendornya resmi.
Mengapa rekam medis tetap terbaca?

Tujuan Pembelajaran

PRADITA University

- Membedakan autentikasi dan otorisasi pada API, serta peran *API key*, token, dan *scope*.
- Menjelaskan alur OAuth (*Open Authorization*) 2.0 yang umum dipakai aplikasi dan mitra pada tingkat konsep.
- Menilai risiko keamanan integrasi yang berjalan dengan OWASP (*Open Worldwide Application Security Project*) API Security Top 10 edisi 2023.

Diagram Konsep Bab 6

IT40613 / BAB 06 / DIAGRAM KONSEP

Token valid tetap memerlukan izin atas objek



Gateway memeriksa akses umum. Layanan wajib memeriksa otorisasi objek dan tindakan pada setiap permintaan.

Pola Insiden Kebocoran Data Lewat API

Risiko Muncul Saat Akses Melebihi Kewenangan

PRADITA University

- Kemampuan dan data diekspos melebihi kewenangan pemanggil.
- Asalnya: otorisasi objek lemah, autentikasi salah, konsumsi berlebihan, dan kepercayaan berlebih pada pihak ketiga.
- Jalur API dirancang untuk dipanggil mesin dalam jumlah besar.
- Daftar OWASP memberi pertanyaan, bukan bukti penyebab.

Analogi: kartu gedung menjawab siapa yang masuk, kunci lemari menjawab arsip mana yang boleh dibuka.

Dua Insiden dari Laporan Publik

PRADITA University

Insiden	Jalur	Waktu	Pelajaran
T-Mobile, 2022 sampai 2023	Satu API, tanpa otorisasi, sekitar 37 juta akun	Sekitar 25 November sampai 5 Januari: 41 hari	Lama berjalan tanpa terlihat
Salesloft Drift, 2025	Token OAuth curian milik aplikasi pihak ketiga	Paling awal 8 Agustus, dicabut 20 Agustus: 12 hari	Platform kuat tetap kehilangan data lewat token mitra

Banyak akun T-Mobile tidak memuat seluruh bidang data. Laporan Drift menegaskan masalahnya bukan celah pada platform inti Salesforce.

Lima Unsur yang Diperiksa

PRADITA University

Unsur	Pertanyaan	Kegagalan yang umum	Butir OWASP
Identitas	Siapa pemanggil, apakah buktinya masih sah?	Kredensial dipakai bersama, masa berlaku tidak diperiksa	API2
Kewenangan	Objek, bidang, dan aksi mana yang boleh?	Token sah membaca pasien lain	API1, API3, API5
Konsumsi	Berapa banyak yang boleh diambil?	Data ditarik terus tanpa batas	API4, API6
Inventaris	Jalur apa yang hidup, siapa pemiliknya?	Versi lama aktif, aliran data tidak tercatat	API9
Kepercayaan	Apakah masukan pihak ketiga diperiksa?	Respons vendor diterima tanpa validasi	API10

Enkripsi tidak menjawab kelimanya. Misalkan 1 persen dari 1.100 hasil salah ID: 11 hasil per bulan tetap diteruskan.

Kasus Medikara: Insiden Vendor 2025 (Data Latihan)

PRADITA University

- Misalkan akun dukungan vendor masih aktif setelah kontrak pekerjaan selesai.
- Akun itu memanggil API bawaan Sistem Informasi Manajemen Rumah Sakit (SIMRS) di 2 rumah sakit: 155 kali per malam, 8 malam, 1.240 rekam kunjungan.
- Semua panggilan membawa kredensial sah, sehingga autentikasi berhasil.
- Diketahui pada hari ke-11, lewat keluhan pasien.
- Catatan rinci disimpan 7 hari: 620 rekam dapat ditelusuri, 620 rekam tidak.

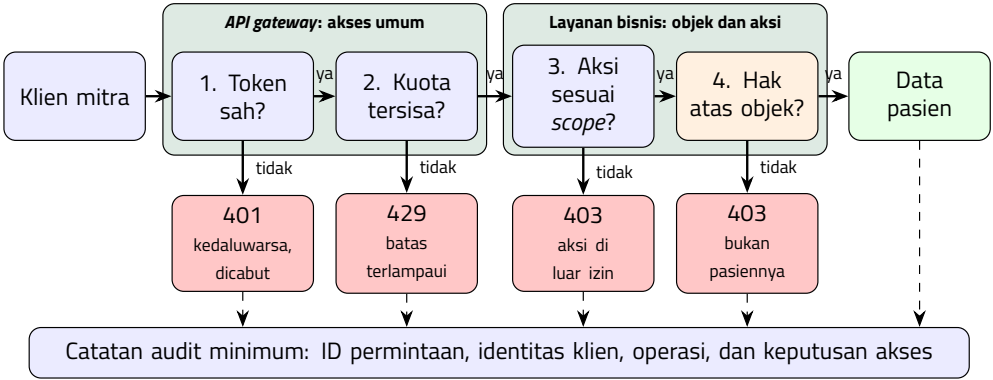
Identitas dan Hak adalah Dua Pertanyaan

PRADITA University

- Autentikasi memeriksa identitas. Otorisasi memutuskan tindakan yang diizinkan.
- Kode 401: identitas belum terbukti, misalnya token kedaluwarsa. Kode 403: terbukti, tetapi tidak berhak.
- Token akses membawa hak berjangka. Token *bearer* dipakai pihak yang memegangnya, sehingga dijaga seperti kunci.
- *Audience* token adalah layanan tujuan, berbeda dari audiens API pada Bab 4.

Analogi: kartu anggota perpustakaan menunjukkan keanggotaan, izin petugas menentukan arsip yang boleh dipinjam.

Empat Pemeriksaan pada Satu Permintaan



Tiap Bukti Menjawab Satu Pertanyaan

PRADITA University

Bukti	Yang dijawab	Yang tidak dijawab	Yang dilakukan
API key	Aplikasi atau proyek mana	Pengguna mana, pasien mana	Lindungi dan rotasi
Token akses	Hak apa, sampai kapan, untuk layanan mana	Apakah objek ini termasuk hubungan layanan	Periksa masa berlaku dan *audience*
Scope	Jenis aksi	Pasien dan fasilitas mana	Beri sekecil mungkin
Objek pasien	Hubungan layanan	Apakah tujuannya sah	Periksa pada server

Contoh Berangka: Scope, Kredensial, Masa Berlaku

PRADITA University

- 240 hasil per hari untuk 40 klinik: 6 hasil per klinik. Hanya memeriksa *scope* berarti 234 hasil lain terbuka.
- Misalkan kredensial dipakai bersama 40 klinik, 2 jam per klinik: Rp4,8 juta.
- Dengan identitas per mitra: satu klinik, Rp120.000, jejak jelas.
- Misalkan bocor 30 hari, kuota 300: 9.000 panggilan. Token 15 menit: paling banyak 300.
- Rahasia klien yang dicuri tetap menghasilkan token baru, sehingga tetap dirotasi.

OAuth 2.0:
Peran dan Dua Alur Utama

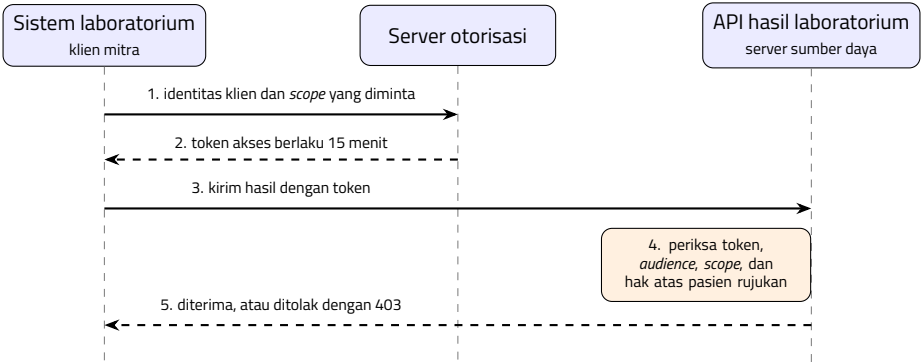
Empat Peran OAuth 2.0

PRADITA University

Peran	Arti	Contoh Medikara
Pemilik sumber daya (*resource owner*)	Pihak yang dapat memberi akses	Pasien atau organisasi
Klien (*client*)	Aplikasi yang meminta akses	Medikara+, sistem laboratorium
Server otorisasi (*authorization server*)	Menerbitkan token	Layanan identitas Medikara
Server sumber daya (*resource server*)	Melayani data bila sah	API hasil laboratorium

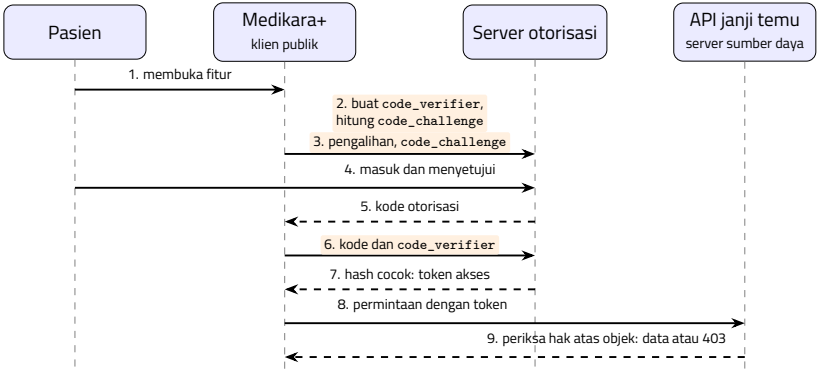
Analogi: surat kuasa membatasi tindakan penerima kuasa, dan loket tetap memeriksa isi surat.

Alur Client Credentials



Tidak ada pasien yang masuk dan tidak ada layar persetujuan. Klien bertindak untuk kepentingannya sendiri

Alur Authorization Code dengan PKCE



Pihak yang hanya menangkap kode pada langkah 5 tidak dapat menebusnya, karena tidak memegang `code_verifier`

Contoh Berangka Dua Alur

PRADITA University

- INT-06, 3 laboratorium, misalkan token 15 menit: paling banyak 48 token per laboratorium, 144 token per hari.
- Satu laboratorium dicabut: token terakhir mati paling lama 15 menit, dua lainnya tidak terganggu.
- Ponsel adalah klien publik, sehingga rahasia yang ditanam dapat dibongkar.
- Misalkan 0,1 persen dari 28.000 sesi kodenya tertangkap: 28 sesi. PKCE membuat kode itu tidak dapat ditebus.
- RFC 9700 mewajibkan *Proof Key for Code Exchange* (PKCE) untuk klien publik.

Memilih Alur Menurut Pihak yang Diwakili

PRADITA University

Keadaan	Alur	Alasan	Contoh Medikara
Aplikasi server, tanpa pengguna	*Client credentials*	Tidak ada pasien yang masuk, klien menjaga rahasia	INT-06, INT-07
Aplikasi mewakili pasien atau dokter	*Authorization code* dengan PKCE	Sandi hanya masuk ke server otorisasi	Medikara+, INT-03
Aplikasi meminta sandi pasien	Tidak dipakai	RFC 9700 melarang alur sandi pemilik	Pola lama
Token langsung lewat pengalihan	Dihindari	RFC 9700 menyarankan tidak memakai *implicit*	Pola lama

INT-03: API privat menggantikan akun basis data yang membaca 140 tabel, kebutuhannya 2 tabel.

OpenID Connect Menambah Lapisan Identitas

PRADITA University

Unsur	Token akses (OAuth 2.0)	*ID Token* (OpenID Connect)
Yang dijawab	Apa yang boleh dilakukan klien	Siapa pengguna yang baru masuk
Ditujukan kepada	Server sumber daya	Klien
Dipakai untuk	Memanggil API	Memulai sesi masuk di aplikasi
Salah pakai yang umum	Dijadikan bukti masuk	Dikirim ke API sebagai izin

Misalkan 12 dokter pindah per tahun, 3 aplikasi: tanpa identitas bersama ada 36 akun yang harus ditutup. Dengan satu server otorisasi cukup 12.

Persetujuan Pemilik Data Punya Dua Lapis

- UU 27/2022: data kesehatan adalah data pribadi spesifik (Pasal 4).
- Persetujuan eksplisit hanya satu dari enam dasar pemrosesan (Pasal 20).
- Permenkes 24/2022: isi rekam medis wajib dijaga kerahasiaannya (Pasal 32), dan pembukaannya terbatas sesuai kebutuhan (Pasal 33).
- Layar persetujuan mencatat izin pasien kepada satu klien.
- Layar belum tentu memadai sebagai dasar hukum.

Analogi: formulir izin tindakan berlaku untuk satu tindakan tertentu.

Layar Persetujuan dan Dasar Pemrosesan

PRADITA University

Situasi	Alur	Layar	Dasar yang diuji fungsi hukum
Pasien mengizinkan aplikasi pihak ketiga	*Authorization code* dengan PKCE	Ada, per klien dan *scope*	Persetujuan eksplisit
Pasien memakai Medikara+	*Authorization code* dengan PKCE	Dicatat saat mendaftar	Perjanjian atau persetujuan
Laboratorium mengirim hasil rujukan	*Client credentials*	Tidak ada	Perjanjian dan persetujuan pasien untuk pengobatan
INT-01, INT-02 ke pihak wajib	Spesifikasi pihak wajib	Tidak ada	Kewajiban hukum

INT-01: pemeriksaan kepesertaan tidak membuka isi rekam medis, sehingga 55.000 layar per bulan tidak menyelesaikan apa pun. Klaim memakai persetujuan saat registrasi (Permenkes 24/2022 Pasal 34 ayat (7)). Kolom terakhir adalah hipotesis, bukan pendapat hukum.

Praktik Utama RFC 9700

PRADITA University

Praktik	Isi RFC 9700	Arti bagi Medikara
Alur aman	Klien publik wajib PKCE, klien rahasia dianjurkan	Medikara+ dan portal mitra memakai PKCE
Pengalihan	Wajib dicocokkan secara persis	Alamat terdaftar per klien
Alur lama	Alur sandi dilarang, *implicit* sebaiknya tidak	Vendor peminta sandi masuk daftar kesenjangan
Token curian	Sebaiknya terikat pengirim: mTLS atau DPoP	Token API mitra diikat ke kunci klien
Hak minimum	Sekecil kebutuhan, dibatasi *audience*	Token API hasil tidak berlaku di API tagihan
Refresh token	Klien publik: terikat pengirim atau dirotasi	Medikara+ merotasi *refresh token*

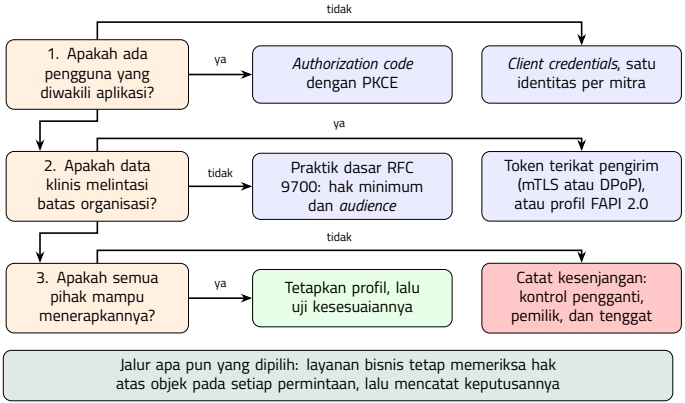
mTLS: *mutual Transport Layer Security*. DPoP: *Demonstrating Proof of Possession*.

OAuth 2.1 dan FAPI 2.0

PRADITA University

- OAuth 2.1 masih *Internet-Draft*: draf ke-16, diperbarui 2 September 2026.
- *Financial-grade API* (FAPI) 2.0 dirancang untuk data bernilai tinggi dan sensitif, termasuk kesehatan elektronik.
- FAPI 2.0 hanya mendukung klien rahasia dan token terikat pengirim, serta mewajibkan PKCE S256.
- Medikara+ di ponsel adalah klien publik, sehingga perlu perubahan arsitektur.
- Spesifikasi BPJS Kesehatan dan SATUSEHAT ditentukan pihak wajib (Bab 7).

Peta Keputusan Alur dan Profil



Contoh Berangka: Biaya dan Kesiapan Mitra

PRADITA University

- Misalkan profil ketat menambah 20 persen: Rp9 juta dari Rp45 juta per antarmuka.
- Pada 20 sambungan aktif: tambah Rp180 juta per tahun.
- Misalkan hanya 5 sambungan data klinis: tambah Rp45 juta per tahun, seperempatnya.
- Misalkan 12 dari 40 klinik mampu DPoP: 28 klinik tertahan, 168 dari 240 hasil tetap lewat telepon.
- Kesenjangan dicatat dengan pemilik dan tenggat, bukan dilabeli patuh.

PRADITA University

OWASP API Security Top 10 Edisi 2023

Sepuluh Butir: API1 sampai API5

PRADITA University

Butir	Arti sederhana	Contoh Medikara
API1 *Broken Object Level Authorization* (BOLA)	Mengganti ID, memperoleh objek pihak lain	Token klinik A membaca pasien klinik B
API2 *Broken Authentication*	Bukti identitas lemah	Kredensial dipakai bersama
API3 *Broken Object Property Level Authorization*	Melihat bidang yang bukan haknya	Rekap perusahaan memuat diagnosis
API4 *Unrestricted Resource Consumption*	Tanpa batas laju, ukuran, biaya	Klinik menarik ribuan hasil per jam
API5 *Broken Function Level Authorization*	Akun biasa memakai fungsi peran lain	Akun klinik memakai fungsi hapus hasil

Sepuluh Butir: API6 sampai API10

PRADITA University

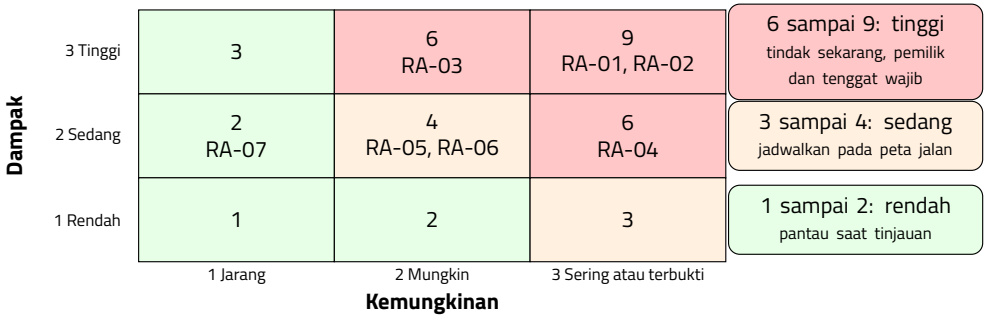
Butir	Arti sederhana	Contoh Medikara
API6 *Unrestricted Access to Sensitive Business Flows*	Alur sah dipakai berlebihan secara otomatis	Program otomatis memborong slot dokter
API7 *Server Side Request Forgery*	Server dipaksa memanggil alamat dari pemanggil	Fitur ambil rujukan memanggil server internal
API8 *Security Misconfiguration*	Konfigurasi longgar	Pesan *error* membuka rincian SIMRS
API9 *Improper Inventory Management*	API atau aliran data tanpa catatan	INT-10: 12 sambungan tanpa pemilik
API10 *Unsafe Consumption of APIs*	Data pihak ketiga dipercaya tanpa periksa	Hasil laboratorium langsung masuk SIMRS

Membaca Daftar OWASP dengan Kritis

PRADITA University

- API1 (BOLA): mudah dieksploitasi, tersebar luas, mudah dideteksi, karena server mengandalkan ID dari klien.
- Edisi 2023 tidak berbasis data: prevalensi berasal dari konsensus tim.
- Penilaian OWASP tidak memperhitungkan dampak nyata pada bisnis, sehingga organisasi tetap menilainya.
- API1 bertanya pasien mana, API3 bidang mana, API5 fungsi mana.
- API10 tentang data yang masuk dari pihak ketiga, bukan semua masalah vendor.

Matriks Dampak dan Kemungkinan



Contoh Register Risiko (Data Latihan)

PRADITA University

ID	Integrasi	Butir	Temuan	Skor	Status bukti
RA-01	INT-03	API3	Akun vendor membaca 140 tabel, kebutuhan 2 tabel	9	Terverifikasi
RA-02	INT-03	API1	API bawaan di 2 rumah sakit diduga tidak memeriksa hubungan layanan	9	Hipotesis
RA-03	INT-10	API9	12 sambungan resep tanpa pemilik dan catatan aliran data	6	Belum terverifikasi
RA-04	INT-07	API3	Rekap 36 perusahaan memuat data karyawan lebih dari kebutuhan	6	Terverifikasi
RA-05	INT-06	API2	Hasil 3 laboratorium lewat surel, pengirim tidak diuji	4	Wawancara
RA-06	INT-02	API10	Jawaban SATUSEHAT tidak diperiksa, 4 persen belum terkirim	4	Terverifikasi
RA-07	Usulan API hasil	API4	Kuota 300 per hari per klinik belum diterapkan	2	Rancangan

Skor tinggi dengan status hipotesis berarti uji berizin, bukan temuan terbukti. Uji hanya pada sistem sendiri atau berizin tertulis.

Laju, Kuota, dan Akibatnya

PRADITA University

- *Rate limiting* membatasi laju, kuota membatasi jumlah dalam periode.
- Misalkan penyalahgunaan 5 permintaan per detik: 216.000 dalam 12 jam tanpa batas.
- Batas 1 permintaan per detik: 43.200. Kuota 300: berhenti setelah 60 detik, lalu 429.
- Kapasitas 40 klinik tetap 12.000 panggilan per hari.
- Pola 155 panggilan per malam lolos dari kuota: yang menghentikan adalah hak atas objek.

Isi Catatan Akses

Dicatat	Tidak dicatat
ID permintaan dan waktu	Token akses dan rahasia klien
Identitas klien dan akun	Sandi pengguna
Operasi dan ID objek	Isi rekam medis dan hasil pemeriksaan
Keputusan akses dan alasannya	Kunci enkripsi

Misalkan 444.000 catatan per bulan: 2,7 GB per tahun. Bila isi ikut dicatat: 266,4 GB, dan *log* menjadi salinan kedua rekam medis.

UU 27/2022 Pasal 46: pemberitahuan paling lambat 3×24 jam, memuat data yang terungkap, kapan, dan bagaimana.

Aktivitas: Penilaian Risiko Keamanan API

PRADITA University

- Pilih tiga integrasi dari peta Bab 5 dengan akibat terbesar bila disalahgunakan.
- Isi daftar periksa OWASP per integrasi, tanpa menguji sistem luar.
- Kumpulkan bukti dari sumber berizin, tandai yang masih hipotesis.
- Beri nilai dampak dan kemungkinan, lalu jalankan `hitung-risiko-api.py`.
- Tetapkan pemilik, kontrol sementara, dan tanggal tinjau untuk temuan tinggi.

Aktivitas: Peran, Luaran, dan Kriteria

- Hukum, kesehatan, bisnis: dampak pada pasien, kepatuhan, reputasi.
- Teknis: bukti autentikasi, akses per objek, dan pencatatan.
- Luaran untuk tonggak C2: lembar periksa, register risiko, catatan keputusan.
- Kriteria: konsep 25%, keterlacakan bukti 30%, alasan keputusan 30%, keterbacaan 15%.
- Berkas: `sources/chapter06/README.md`.

Pemindaian, uji beban, dan uji hak akses hanya untuk sistem sendiri atau yang sudah berizin tertulis.

Ringkasan

- Risiko API muncul ketika akses melebihi kewenangan pemanggil.
- *API key*, token, dan *scope* tidak menjawab pasien yang mana.
- *Client credentials* untuk aplikasi server, PKCE untuk aplikasi yang mewakili pasien.
- OWASP memberi pertanyaan, bukan vonis dan bukan prioritas.
- Pesan utama: token yang sah bukan izin atas semua data.

Latihan

PRADITA University

1. Jelaskan dengan contoh rekam medis mengapa *Broken Object Level Authorization* menempati urutan pertama.
2. Bandingkan pemakaian *API key* dan OAuth 2.0 *client credentials* untuk integrasi dengan laboratorium mitra.
3. Kebocoran data Medikara pada 2025 terjadi lewat vendor. Tentukan dua butir OWASP API Security Top 10 yang paling relevan, lalu jelaskan alasannya.